

SSRF TO RCE LAB

from Nguyễn Bá Hải Long

MỤC LỤC

MỤC LỤC	1
DANH MỤC HÌNH VẼ	2
I. Hệ thống:	3
II. Mô tả lab:	3
III. Kịch bản tấn công:	4
IV. Lỗ hổng:	4
1. Xác định vị trí lỗ hổng SSRF cần khai thác:	4
2. Khai thác lỗ hổng SSRF:	5
3. Lỗ hổng upload file:	6
V. Cách vượt qua bài lab:	7

DANH MỤC HÌNH VẼ

Hình 1: POST request từ chức năng tìm kiếm.....	5
Hình 2: File api thực hiện tiếp nhận yêu cầu.....	5
Hình 3: Cấu hình blacklist trong find.php.....	6
Hình 4: Đoạn code phân giải host	6
Hình 5: Cấu hình chức năng upload file.....	7
Hình 6: Tại chức năng tìm kiếm, người chơi thực hiện tìm kiếm file.....	7
Hình 7: Gói tin thực hiện chức năng tìm kiếm.....	7
Hình 8: Người chơi bypass blacklist và truy cập vào admin interface.....	8
Hình 9: Thực hiện crack mật khẩu admin tìm được	8
Hình 10: Upload file payload.php	8
Hình 11: Reverse shell và đọc flag.txt.....	8

I. Hệ thống:

Hệ thống gồm 2 trang web chính:

- **Webapp chia sẻ tài liệu của admin gồm các chức năng:**
 - **Đăng nhập:**
 - Thực hiện xác thực, đăng nhập người dùng vào hệ thống gồm 2 trường nhập username và password.
 - Dữ liệu người dùng được mã hóa dưới dạng sha256 trước khi so với cơ sở dữ liệu.
 - Khi người dùng đăng nhập sai hiển thị thông báo "tài khoản hoặc mật khẩu sai yêu cầu đăng nhập lại"
 - Nếu đăng nhập sai quá 3 lần, khóa trường username, password và nút confirm đăng nhập trong 1p.
 - **Trang chủ:**
 - Hiển thị các file tài liệu được admin gửi lên dưới dạng đường dẫn.
 - Khi click vào đường dẫn tài liệu thì nó thực thi đọc file và chuyển đến trang view.
 - Hiển thị nút tìm kiếm.
 - Hiển thị chỗ upload file (chỉ hiển thị khi người dùng là admin truy cập vào hệ thống).
 - **Tìm kiếm (nơi bị khai thác SSRF):**
 - Thực hiện tìm kiếm tài liệu dựa trên chuỗi kí tự được nhập. Web sẽ truy vấn giao tiếp với database thông qua API.
 - Trước khi truy vấn, web lọc đường dẫn qua blacklist chặn điều hướng đến <http://localhost/admin> (admin interface). Cụ thể chặn IPv6, chặn mọi biến thể IPv4 gồm 4 phân đoạn (x.x.x.x), chặn decimal/hex, chặn các ký tự đặc biệt ('localhost', 'localtest.me', 'nip.io', 'vcap.me').
 - **Upload file:**
 - Thực hiện upload file từ máy tính cá nhân lên server.
 - Cho phép admin gửi bất kì file nào admin muốn.
- **Admin interface:**
 - Chỉ có nội bộ mới được truy cập.
 - Để lộ tài khoản mật khẩu của admin dưới dạng `username:sha256(password)`

Hệ thống có cơ sở dữ liệu như sau:

- **Bảng Story:** chứa tên file và đường dẫn truy cập file đó trong hệ thống.
- **Bảng User:** chứa dữ liệu đăng nhập người dùng có cấu trúc `username:sha256(password)`.

II. Mô tả lab:

Trong bài lab này, chức năng tìm kiếm lấy dữ liệu nằm trong máy nội bộ. Để vượt qua được bài lab này, cần thay đổi API của chức năng tìm kiếm nhằm truy cập vào giao diện admin của hệ thống nằm tại <http://localhost/admin/>. Từ thông tin có được ta thực hiện RCE hệ thống và đọc file flag.txt.

Người chơi được cấp sẵn tài khoản người dùng thường **steve:123456** để truy cập vào trang web.

Lập trình viên đã thiết lập các lớp phòng thủ chống SSRF mà người chơi cần vượt qua để tới giao diện admin.

Hint: admin có thể upload bất kì file nào admin muốn lên hệ thống.

III. Kịch bản tấn công:

1. Attacker được cấp 1 tài khoản người dùng bình thường **steve:123456** để truy cập vào trang web.
2. Attacker sử dụng chức năng tìm kiếm để tìm kiếm file trong cơ sở dữ liệu.
3. Server truy vấn vào đường dẫn API đến database để lấy file.
4. Attacker sử dụng phương pháp SSRF, thay đổi đường dẫn API gọi đến trang admin interface <http://localhost/admin>
5. Attacker nhận được tài khoản, mật khẩu của admin dưới dạng `username:sha256(password)`.
6. Attacker sử dụng bruteforce để có được password admin.
7. Attacker đăng nhập tài khoản admin trong webapp và thực hiện upload file độc hại, đọc file độc hại đấy ngay trên webapp và attacker có được shell của máy.
8. Attacker đọc file flag.txt. Kết thúc lab.

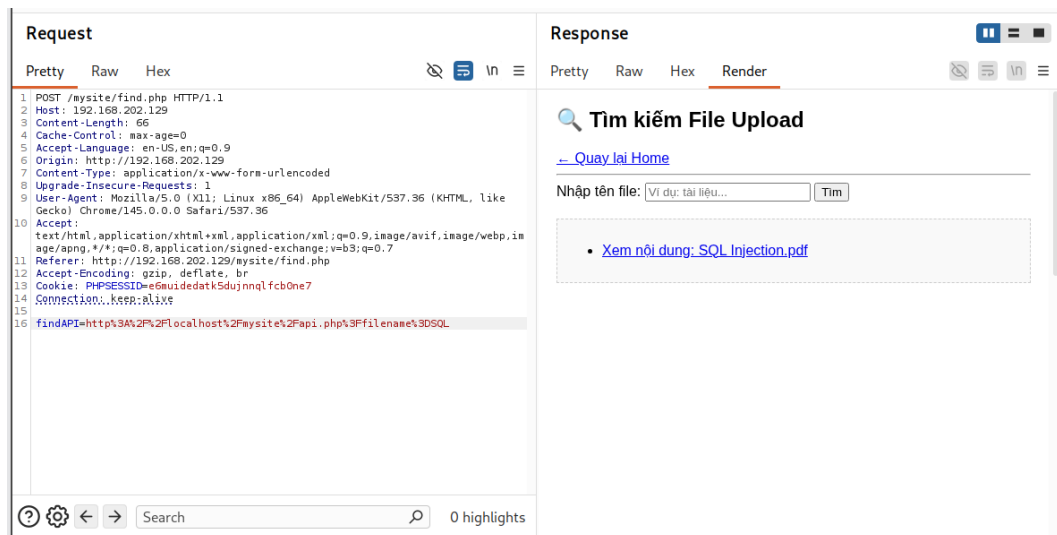
Tổng quát chuỗi tấn công như sau:

SSRF → Information Disclosure → Password Cracking → Authentication
Bypass/Privilege Escalation → RCE.

IV. Lỗ hổng:

1. Xác định vị trí lỗ hổng SSRF cần khai thác:

Khi thực hiện chức năng tìm kiếm thì ta thấy gói tin có cấu trúc như sau:



Hình 1: POST request từ chức năng tìm kiếm

Trong đó:

- findAPI chính là đường dẫn mà webapp thực hiện truy cập đến để lấy dữ liệu về. (cụ thể định hướng đến file api.php)

```

api.php
1 <?php
2 require_once 'db.php';
3
4 header('Content-Type: application/json');
5
6 if (isset($_GET['filename'])) {
7     $search = trim($_GET['filename']);
8
9
10    $stmt = $conn->prepare("SELECT filename, filepath FROM Story WHERE filename LIKE ?");
11    $search_param = "%" . $search . "%";
12    $stmt->bind_param("s", $search_param);
13    $stmt->execute();
14
15    $result = $stmt->get_result();
16    $data = [];
17
18    if ($result && $result->num_rows > 0) {
19        while($row = $result->fetch_assoc()) {
20            $data[] = [
21                'filename' => $row['filename'],
22                'filepath' => $row['filepath']
23            ];
24        }
25    }
26    $stmt->close();
27
28    // Trả về JSON cho find.php đọc
29    echo json_encode(["status" => "success", "results" => $data]);
30 } else {
31     echo json_encode(["status" => "error", "message" => "Thiếu tham số filename"]);
32 }
33 ?>

```

Hình 2: File api thực hiện tiếp nhận yêu cầu

2. Khai thác lỗ hổng SSRF:

Như đã đề cập ở phần mô tả hệ thống blacklist thực hiện chặn những truy vấn sau:

- IPv6,
- Mọi biến thể IPv4 gồm 4 phân đoạn (x.x.x.x),
- Decimal/hex
- Chặn các ký tự đặc biệt ('localhost', 'localtest.me', 'nip.io', 'vcap.me').

```

<?php
function is_blacklisted($url) {
    // Danh sách đen cơ bản
    $blacklist = ['localhost', 'localtest.me', 'nip.io', 'vcap.me'];

    if(strpos($url, 'http://localhost/mysite/api.php?filename=') !== false) {
        return false;
    }

    $host = parse_url($url, PHP_URL_HOST);
    if (!$host) return true;

    // 1. CHẶN TRIỆT ĐỀ IPv6:
    // Mọi địa chỉ IPv6 khi nằm trong URL bắt buộc phải có dấu ngoặc vuông []
    // hoặc chứa dấu hai chấm : (nếu là host thô)
    if (strpos($host, '[') !== false || strpos($host, ':') !== false) {
        return true;
    }

    // 2. Chặn IP có 4 phân đoạn (Ngăn chặn 127.0.0.1 và mọi biến thể X.X.X.X)
    if (preg_match('/^\d+\.\d+\.\d+\.\d+$/i', $host)) return true;

    // 3. Chặn các dạng số lặ (Decimal, Hex)
    if (preg_match('/^0x[0-9a-f]+$/i', $host) || preg_match('/^\d{10}$/i', $host)) return true;

    foreach ($blacklist as $bad_word) {
        if (strpos(strtolower($url), strtolower($bad_word)) !== false) {
            return true;
        }
    }
    return false;
}

```

Hình 3: Cấu hình blacklist trong find.php

Sau khi qua được black list thì nó sẽ tiến tới phân giải host

```

// Tách lấy phần host để kiểm tra
$parsed_url = parse_url($target_url);
if (isset($parsed_url['host'])) {
    $host = $parsed_url['host'];

    // gethostbyname sẽ cố gắng phân giải 127.1 thành 127.0.0.1
    $resolved_ip = gethostbyname($host);

    // Thay thế lại host cũ bằng IP đã phân giải (nếu cần)
    $target_url = str_replace($host, $resolved_ip, $target_url);
}

```

Hình 4: Đoạn code phân giải host

Mục tiêu chính là phân giải các địa chỉ rút gọn thành địa chỉ đầy đủ để truy vấn. Lỗ hổng tồn tại do blacklist chỉ chặn truy vấn các địa chỉ IPv4 với 4 phân đoạn x.x.x.x chứ không chặn các địa chỉ IPv4 rút gọn như 2 phân đoạn x.x hay 3 phân đoạn x.x.x. Từ đó để truy vấn tới localhost, người chơi chỉ cần truy cập địa chỉ localhost rút gọn vd: 127.1 hay 127.0.1 là bypass được blacklist. (**bypass url:** http://127.1/admin/)

3. Lỗ hổng upload file:

Chỉ có admin mới có thể upload file và server chấp nhận mọi file mà admin upload. Dựa vào tài khoản mật khẩu để lộ ở admin interface, người chơi có thể upload file tùy thích, truy cập file payload đó, reverse shell về máy mình và cuối cùng đọc file flag.txt để hoàn thành lab.

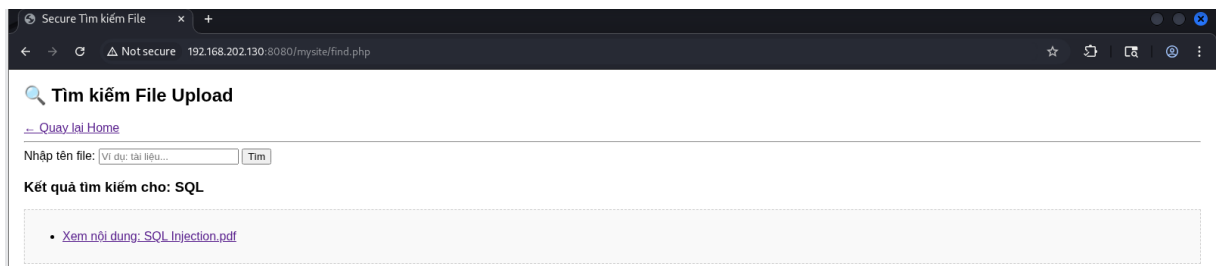
```

--
12 // XỬ LÝ UPLOAD FILE (Chỉ dành cho Admin)
13 if ($is_admin && $_SERVER["REQUEST_METHOD"] == "POST" && isset($_FILES["fileToUpload"])) {
14     $target_dir = "upload/";
15     $filename = basename($_FILES["fileToUpload"]["name"]);
16     $target_file = $target_dir . $filename;
17
18     if (move_uploaded_file($_FILES["fileToUpload"]["tmp_name"], $target_file)) {
19         $sql = "INSERT INTO Story (filename, filepath) VALUES ('$filename', '$target_file')";
20         $conn->query($sql);
21         $msg = "Upload thành công!";
22     } else {
23         $msg = "Có lỗi xảy ra khi upload.";
24     }
25 }
26 ?>

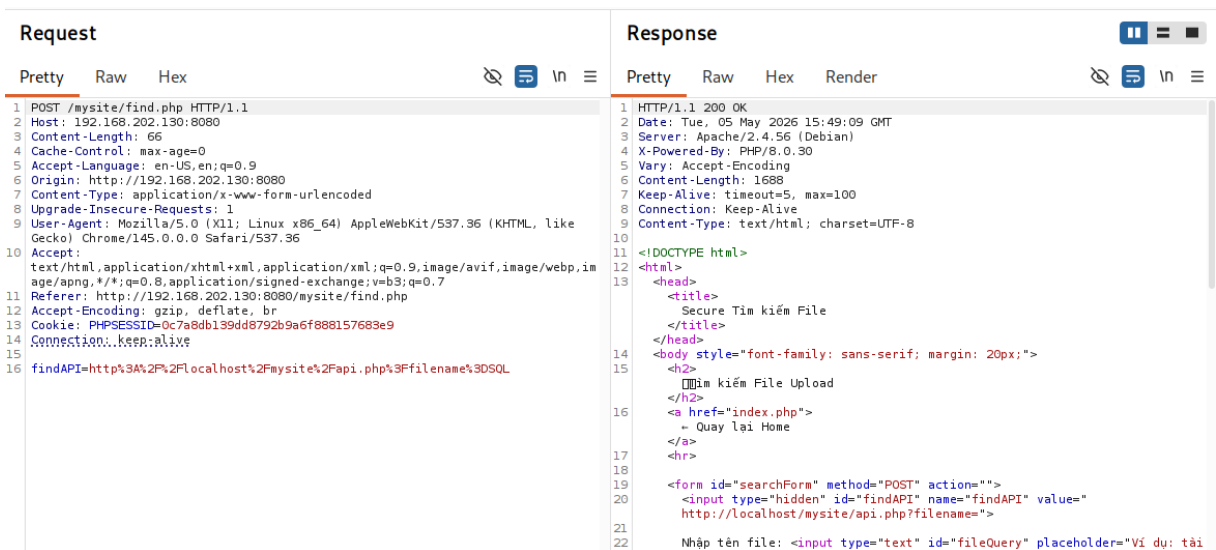
```

Hình 5: Cấu hình chức năng upload file

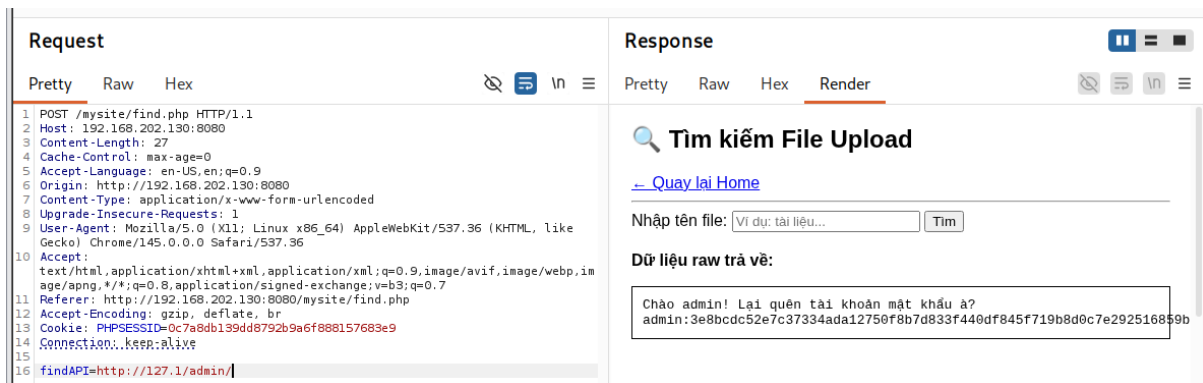
V. Cách vượt qua bài lab:



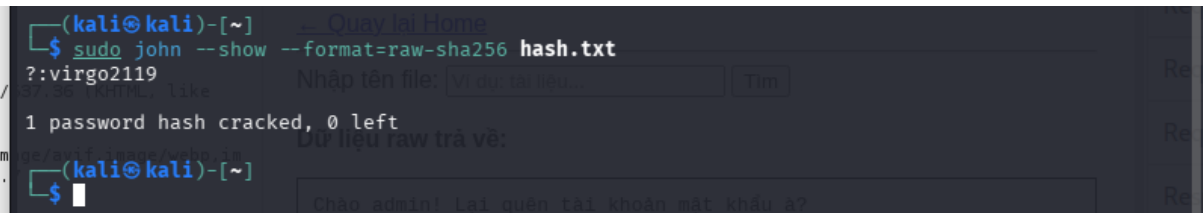
Hình 6: Tại chức năng tìm kiếm, người chơi thực hiện tìm kiếm file



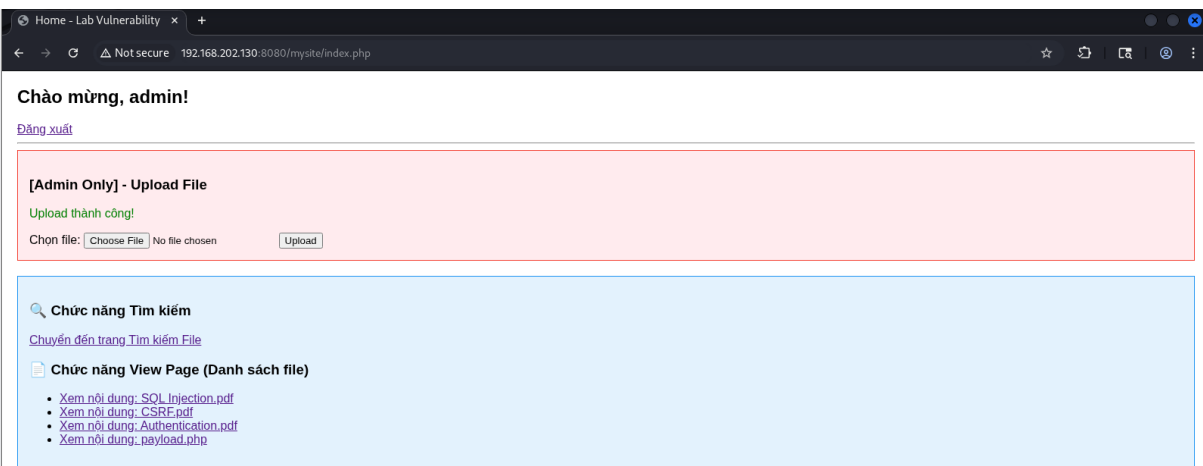
Hình 7: Gợi tin thực hiện chức năng tìm kiếm



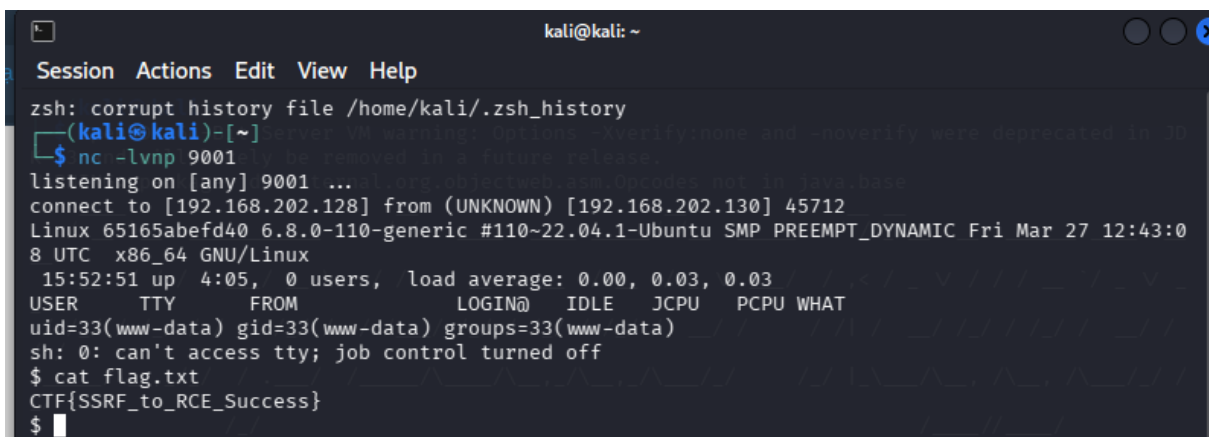
Hình 8: Người chơi bypass blacklist và truy cập vào admin interface



Hình 9: Thực hiện crack mật khẩu admin tìm được



Hình 10: Upload file payload.php



Hình 11: Reverse shell và đọc flag.txt